PRIVACIDADE DE DADOS · PROJETO TEÓRICO-PRÁTICO

Seminário de apresentação

Engenharia Social e Phishing

Exploração do fator humano, impacto na privacidade dos dados e simulação prática com GoPhish

Grupo

Nuno Rosário (146810) · Pedro Portugal (122412) · Sérgio Silva (111052)

Tiago Inácio (110890) · Tomás Saraiva (142847)

Docente: Valderi Leithardt

12 de novembro de 2026

AGENDA

Duas partes, um fio condutor

PARTE 1 · Contexto

Porque é que isto importa

- Engenharia social e phishing
- O fator humano e a manipulação
- Impacto financeiro e empresarial
- Novas tendências: IA e deepfakes
- As regras do jogo (RGPD, NIS2, ISO)

PARTE 2 · Projeto prático

A simulação, em destaque

- Objetivo e abordagem experimental
- Arquitetura e automação (GoPhish)
- Resultados e matriz do 1.º clique
- Limitações, ética e privacidade
- Defesas e demonstração ao vivo

CONTEXTO · O ELO HUMANO

A segurança técnica não chega se a pessoa for enganada

Engenharia social é manipular pessoas para obter dados ou acessos; o **phishing** é a sua forma mais comum — mensagens que imitam uma entidade de confiança. O atacante não contorna a firewall, contorna a pessoa.

~60%

das violações envolvem o **elemento humano**

Verizon, 2025

~60%

dos acessos iniciais na UE começam em **phishing**

ENISA, 2025

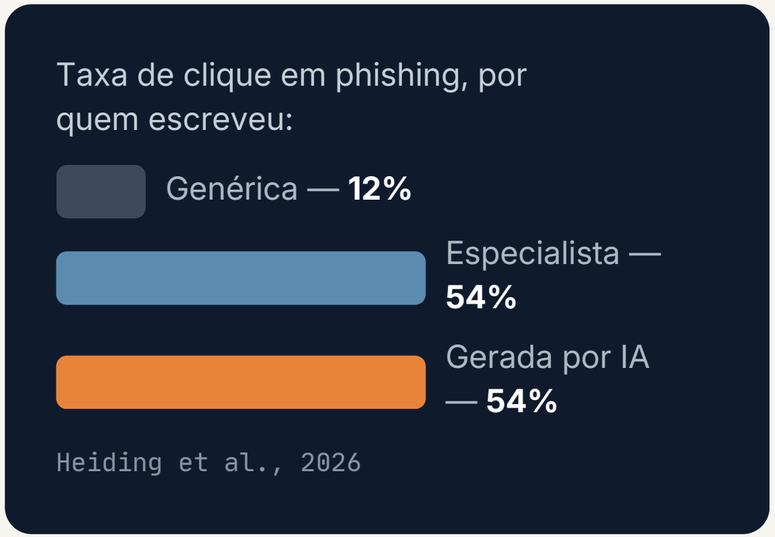
16,6 mil M$

em perdas por cibercrime em 2024 **(+33%)**

FBI / IC3, 2025

TENDÊNCIAS E LIMITES

A IA mudou o jogo — e há regras



A IA iguala o especialista

Mensagens corretas e personalizadas, deepfakes e clonagem de voz: os erros deixam de ser um sinal fiável.

E há limites legais

Os dados de uma simulação são **dados pessoais**: RGPD (base legal, minimização, proteção) e NIS2 aplicam-se.

PROJETO PRÁTICO · OBJETIVO

O ciclo de vida completo de um ataque de phishing simulado

Usámos a framework open-source **GoPhish** para construir, lançar e analisar uma campanha real — e medir empiricamente a suscetibilidade de diferentes perfis de utilizadores.

01

Construir

Infraestrutura e templates do ataque no GoPhish.

02

Executar

Campanhas segmentadas, com consentimento informado.

03

Analisar

Estatísticas de compromisso e defesas (Blue Team).

ABORDAGEM EXPERIMENTAL

Três iscos, uma métrica fiável

Recrutamento com consentimento

Participantes inscritos por Google Forms, com consentimento informado e dados demográficos básicos.

Métrica principal: o 1.º clique

Validado por um identificador único (?rid=). É o único sinal comportamental 100% fiável.

Sem guardar credenciais reais

A análise foca-se apenas nas métricas comportamentais.

OS 3 TEMPLATES

1 · Legítimo
Email institucional neutro — o controlo.

2 · Phishing difícil
Idêntico, mas com um link traiçoeiro.

3 · Phishing óbvio
Urgência e ameaça — o engodo clássico.

ARQUITETURA

Infraestrutura isolada e automatizada

01

Inscrição

Google Forms: consentimento e dados estritamente necessários para a experiência.

DigitalOcean · Ubuntu VPS

02

Automação

Script Python dispara 3 campanhas via API do GoPhish

Docker · GoPhish

03

Envio

Relay SMTP Brevo entrega os emails ao participante

Brevo · SMTP relay

04

Análise

GoPhish regista eventos; Python extrai o 1.º clique

Script (Python · venv)

AUTOMAÇÃO E ORQUESTRAÇÃO

Da inscrição ao envio em segundos

1. Um listener Python recebe a nova inscrição e valida um token de segurança.
2. Comunica com a API do GoPhish e cria **3 campanhas individuais** para aquele email.
3. O Brevo envia; o participante recebe a sequência quase em tempo real.
4. Um segundo script filtra a timeline à procura do evento **Clicked Link,** para organização de resultados**.**

```
POST /api/campaigns/

// recolha de eventos

GET /api/campaigns/{id}

→ "message": "Clicked Link"
```

COMO DECIDIMOS O VEREDICTO

A matriz do 1.º clique

Como cada pessoa recebia os 3 emails, agrupámos os eventos por participante e ordenámos no tempo. O **primeiro clique absoluto** define o veredicto.

Decisão correta

1.º clique no **Email 1** (legítimo). O participante distinguiu o verdadeiro do falso.

Vítima de phishing

1.º clique no **Email 2 ou 3**. Caiu no link de phising antes de reconhecer o legítimo.

O clique é validado pelo identificador único ?rid= — por isso é um sinal comportamental fiável, ao contrário da abertura.

RESULTADOS

O que observámos na campanha

53

participantes no estudo

83%

clicaram em pelo menos um link

35%

1.º clique num link de email phishing

Dos 53 participantes no estudo, 25 identificaram e clicaram corretamente no e-mail legítimo. Em contrapartida, 19 caíram na simulação de phishing traiçoeiro, enquanto a versão óbvia não registou qualquer vítima (0 pessoas). Por fim, 9 participantes optaram por não clicar em nenhuma hiperligação — adotando, na prática, a postura defensiva mais segura.

LIMITAÇÕES E APRENDIZAGENS

O que os dados nos ensinaram

Hover test ficou comprometido por dois fatores

No nosso estudo, o hover test ficou comprometido por dois fatores:

- **Técnico**: O servidor de relay (Brevo) reescreveu os links para o seu próprio domínio de rastreio, mascarando o URL final mesmo para quem passou o cursor por cima no PC.
- **Usabilidade**: Nos smartphones, a ausência de um cursor em ecrãs táteis impede fisicamente a inspeção prévia da hiperligação.

A abertura não é fiável

Sistemas de segurança podem gerar aberturas falsas. Só o clique validado conta.

Viés de quem sabe que vai ser testado

Os participantes inscreveram-se e esperavam os emails, por isso ficaram mais alerta do que numa situação real.

ÉTICA E PRIVACIDADE

Testar pessoas sem as expor

Consentimento informado

Participação voluntária e autorizada via formulário.

Horário e organização de referência

Os participantes receberam os emails na hora que selecionaram e da organizção abordada no formulário.

Minimização

Só métricas comportamentais; dados apagados no fim.

Do ponto de vista legal e ético, o parâmetro ?rid= associado a cada hiperligação converte a métrica de clique num dado pessoal pseudonimizado (Art. 4.º do RGPD), uma vez que permite ligar a conduta individual a uma pessoa identificável. Consequentemente, a simulação sujeitou-se rigorosamente aos princípios de licitude por consentimento (Art. 6.º), minimização e limitação de retenção (Art. 5.º), bem como às obrigações de segurança e notificação de violações de dados no prazo de 72 horas (Art. 33.º).

BLUE TEAM · DEFESAS

Como se trava este ataque

Analisar os dominios

Verificar a coerência entre o remetente e o URL de destino (evitando links para domínios estranhos).

MFA

A salvaguarda final: a credencial roubada não chega para entrar.

Filtragem (Email Gateways)

Bloqueiam a mensagem antes de chegar à caixa de entrada.

Formação e cultura de reporte

Pessoas treinadas detetam — e denunciar depressa trava a campanha.

Nenhuma medida sozinha chega: a resposta é a **defesa em profundidade** — técnica, organizacional e pessoal.

LIVE

DEMONSTRAÇÃO AO VIVO

A campanha GoPhish em direto

Dashboard da campanha · o email tal como chega · o clique a ser registado em tempo real · a timeline de eventos.

CONCLUSÃO

O elo mais fraco continua a ser humano

A eficácia do phishing não está na falha das máquinas, mas na manipulação das pessoas. A IA generativa só torna os ataques mais credíveis, automatizados e difíceis de detetar.

Teoria

O fator humano é o vetor; o enquadramento legal define os limites.

Prática

A simulação mostrou, com dados, como e porquê as pessoas caem.

Defesa

Em profundidade: técnica, organizacional e pessoal.

OBRIGADO

Perguntas?

Engenharia Social e Phishing — exploração do fator humano, impacto na privacidade e simulação com GoPhish.

Nuno Rosário · Pedro Portugal · Sérgio Silva · Tiago Inácio · Tomás Saraiva
Privacidade de Dados · Valderi Leithardt · 2026/2027